

W9D1 - (parte 2) scansioni con nmap

Nella seconda parte dell'esercizio di oggi, vedremo degli esempi di scansione con nmap, un potente strumento di scansione delle reti, utilizzato per identificare i dispositivi connessi, eseguire ricerche avanzate sui sistemi operativi e sulla configurazione dei servizi attivi.

Struttura del laboratorio target

Utilizzeremo il laboratorio che abbiamo implementato fin ora, andando ad effettuare la scansione partendo da una macchina con Kali Linux, e andando a scansare una metasploitable2 con diversi servizi attivi. Le due macchine si trovano su reti diverse ma sono collegate da un firewall pfsense che le mette in comunicazione. Questa conformazione di rete è stata implementata per un altro esercizio e non è stata modificata.

Important

Per questo esercizio, la nostra macchina sarà la kali con indirizzo IP **192.168.50.100**, andremo ad effettuare la scansione di una macchina linux metasploitable2 che risponde all'indirizzo IP **192.168.51.101**, le due sottoreti si parlano tramite un firewall pfsense che le mette in comunicazione, ma *blocca l'accesso alla porta 80 della metasploitable2 da parte della kali.*

Effettueremo 3 tipi di scansione diversa sulle 1000 porte più comuni, generando un report xml per ognuna (con l'opzione `-oX`), che poi convertiremo in html e pdf, per andare poi ad analizzare quanto scoperto.

Scansione TCP

Per questa scansione nmap effettua un 3-way handshake con il servizio come se volesse stabilire una connessione, la sintassi è:

```
1 | nmap -sT -oX scansione_TCP.xml 192.168.51.101
```

Con questa scansione abbiamo trovato 977 porte chiuse, una porta filtrata e 22 porte aperte. La scansione è durata **1.29 secondi**.

Port	Protocol	State	Service	Reason	Product	Version	Extra info
21	tcp	open	ftp	syn-ack			
22	tcp	open	ssh	syn-ack			
23	tcp	open	telnet	syn-ack			
25	tcp	open	smtp	syn-ack			
53	tcp	open	domain	syn-ack			
80	tcp	filtered	http	no-response			
111	tcp	open	rpcbind	syn-ack			
139	tcp	open	netbios-ssn	syn-ack			
445	tcp	open	microsoft-ds	syn-ack			

Port	Protocol	State	Service	Reason	Product	Version	Extra info
512	tcp	open	exec	syn-ack			
513	tcp	open	login	syn-ack			
514	tcp	open	shell	syn-ack			
1099	tcp	open	rmiregistry	syn-ack			
1524	tcp	open	ingreslock	syn-ack			
2049	tcp	open	nfs	syn-ack			
2121	tcp	open	ccproxy-ftp	syn-ack			
3306	tcp	open	mysql	syn-ack			
5432	tcp	open	postgresql	syn-ack			
5900	tcp	open	vnc	syn-ack			
6000	tcp	open	X11	syn-ack			
6667	tcp	open	irc	syn-ack			
8009	tcp	open	ajp13	syn-ack			
8180	tcp	open		syn-ack			

Questa prima scansione ci fornisce già qualche informazione, come lo stato della porta e il servizio in ascolto su di essa.

Scansione SYN

Questa è una scansione meno invasiva della precedente, in questo caso nmap non completa il 3-way handshake ma resetta la connessione dopo il secondo step. La sintassi per questa scansione è:

```
1 | nmap -sS -oX scansione_SYN.xml 192.168.51.101
```

Anche con questa scansione abbiamo trovato 977 porte chiuse, una porta filtrata e 22 porte aperte. La scansione è durata **1.33 secondi**.

Port	Protocol	State	Service	Reason	Product	Version	Extra info
21	tcp	open	ftp	syn-ack			
22	tcp	open	ssh	syn-ack			
23	tcp	open	telnet	syn-ack			
25	tcp	open	smtp	syn-ack			
53	tcp	open	domain	syn-ack			

Port	Protocol	State	Service	Reason	Product	Version	Extra info
80	tcp	filtered	http	no-response			
111	tcp	open	rpcbind	syn-ack			
139	tcp	open	netbios-ssn	syn-ack			
445	tcp	open	microsoft-ds	syn-ack			
512	tcp	open	exec	syn-ack			
513	tcp	open	login	syn-ack			
514	tcp	open	shell	syn-ack			
1099	tcp	open	rmiregistry	syn-ack			
1524	tcp	open	ingreslock	syn-ack			
2049	tcp	open	nfs	syn-ack			
2121	tcp	open	ccproxy-ftp	syn-ack			
3306	tcp	open	mysql	syn-ack			
5432	tcp	open	postgresql	syn-ack			
5900	tcp	open	vnc	syn-ack			
6000	tcp	open	X11	syn-ack			
6667	tcp	open	irc	syn-ack			
8009	tcp	open	ajp13	syn-ack			
8180	tcp	open		syn-ack			

Come si evince dalla tabella, abbiamo ottenuto la stessa risposta del test precedente, senza ulteriori informazioni. Questi due test si distinguono solo per la tipologia di connessione stabilita col server e quindi per il numero di pacchetti inviati da nmap.

Scansione aggressiva (-A)

Questa tipologia di scansione è più aggressiva, include infatti diverse funzionalità:

- [OS Detection](#)
- [Port scanning](#)
 - version detection
- [script scanning](#)
- [traceroute](#)

Sarà quindi una scansione più lunga (la durata si può accorciare con il flag `-T<0-5>` dove un valore più alto significa un'esecuzione più veloce) e approfondita delle precedenti. La sintassi è:

```
1 | nmap -A -oX scansione_A.xml 192.168.51.101
```

Con questa scansione abbiamo trovato lo stesso numero di porte aperte/filtrate/chiuso, ma molte più informazioni sul nostro target. La durata è stata di **130.48 secondi**.

OS Detection

Un esempio di informazioni approfondite è la scansione del sistema operativo, nmap ci restituisce queste informazioni:

Important

- Used port: **21/tcp (open)**
- Used port: **1/tcp (closed)**
- Used port: **31822/udp (closed)**
- OS match: **Linux 2.6.15 - 2.6.26 (likely embedded) (100%)**

Come si vede, ha scoperto il sistema operativo di base della metasploitable2.

Port Scan

Vediamo anche la tabella delle porte come per le scansioni precedenti:

Port	Protocol	State	Service	Reason	Product	Version	Extra info
21	tcp	open	ftp	syn-ack	vsftpd	2.3.4	
	ftp-anon	Anonymous FTP login allowed (FTP code 230)					
	ftp-syst	STAT: FTP server status: Connected to 192.168.50.100 Logged in as ftp TYPE: ASCII No session bandwidth limit Session timeout in seconds is 300 Control connection is plain text Data connections will be plain text vsFTPD 2.3.4 - secure, fast, stable End of status					
22	tcp	open	ssh	syn-ack	OpenSSH	4.7p1 Debian 8ubuntu1	protocol 2.0
	ssh-hostkey	1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA) 2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)					
23	tcp	open	telnet	syn-ack	Linux telnetd		
25	tcp	open	smtp	syn-ack	Postfix smtpd		
	smtp-commands	metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN					
53	tcp	open	domain	syn-ack	ISC BIND	9.4.2	
	dns-nsid	bind.version: 9.4.2					
111	tcp	open	rpcbind	syn-ack		2	RPC #100000
	rpcinfo	program version port/proto service 100000 2 111/tcp rpcbind 100000 2 111/udp rpcbind 100003 2,3,4 2049/tcp nfs 100003 2,3,4 2049/udp nfs 100005 1,2,3 43659/tcp mountd 100005 1,2,3 60621/udp mountd 100021 1,3,4 41637/udp nlockmgr 100021 1,3,4 59000/tcp nlockmgr 100024 1 44217/tcp status 100024 1 56016/udp status					
139	tcp	open	netbios-ssn	syn-ack	Samba smbd	3.X - 4.X	workgroup: WORKGROUP
445	tcp	open	netbios-ssn	syn-ack	Samba smbd	3.0.20- Debian	workgroup: WORKGROUP
512	tcp	open	exec	syn-ack	netkit-rsh rexecd		
513	tcp	open	login	syn-ack			
514	tcp	open	shell	syn-ack	Netkit rshd		
1099	tcp	open	java-rmi	syn-ack	GNU Classpath grmiregistry		
1524	tcp	open	bindshell	syn-ack	Metasploitable root shell		
2049	tcp	open	nfs	syn-ack		2-4	RPC #100003

Port	Protocol	State	Service	Reason	Product	Version	Extra info
2121	tcp	open	ftp	syn-ack	ProFTPD	1.3.1	
3306	tcp	open	mysql	syn-ack	MySQL	5.0.51a-3ubuntu5	
	mysql-info	Protocol: 10 Version: 5.0.51a-3ubuntu5 Thread ID: 9 Capabilities flags: 43564 Some Capabilities: SwitchToSSLAfterHandshake, Support41Auth, LongColumnFlag, Speaks41ProtocolNew, SupportsTransactions, SupportsCompression, ConnectWithDatabase Status: Autocommit Salt: ^1w&V\KEU^Wy}(K"eYm8					
5432	tcp	open	postgresql	syn-ack	PostgreSQL DB	8.3.0 - 8.3.7	
	ssl-date	2025-09-08T13:04:15+00:00; 0s from scanner time.					
	ssl-cert	Subject: commonName=ubuntu804-base.localdomain/organizationName=OC0SA/stateOrProvinceName=There is no such thing outside US/countryName=XX Not valid before: 2010-03-17T14:07:45 Not valid after: 2010-04-16T14:07:45					
5900	tcp	open	vnc	syn-ack	VNC		protocol 3.3
	vnc-info	Protocol version: 3.3 Security types: VNC Authentication (2)					
6000	tcp	open	X11	syn-ack			access denied
6667	tcp	open	irc	syn-ack	UnrealIRCd		
8009	tcp	open	ajp13	syn-ack	Apache Jserv		Protocol v1.3
	ajp-methods	Failed to get a valid response for the OPTION request					
8180	tcp	open	http	syn-ack	Apache Tomcat/Coyote JSP engine	1.1	
	http-favicon	Apache Tomcat					
	http-title	Apache Tomcat/5.5					

Quì vediamo che il volume di informazioni è estremamente maggiore, nmap ci fornisce la versione del software in ascolto su una determinata porta, informazioni riguardanti il protocollo accettato dall'applicazione ecc.

Scripts

Un'altra attività implementata sotto il flag **-A** di nmap è l'esecuzione di alcuni script alla ricerca di eventuali vulnerabilità. Ne vediamo un esempio quà di seguito:

Script Name	Output
smb-security-mode	account_used: <blank> authentication_level: user challenge_response: supported message_signing: disabled (dangerous, but default)
smb2-time	Protocol negotiation failed (SMB2)
smb-os-discovery	OS: Unix (Samba 3.0.20-Debian) Computer name: metasploitable NetBIOS computer name: Domain name: localdomain FQDN: metasploitable.localdomain System time: 2025-09-08T09:02:57-04:00
nbstat	NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
clock-skew	mean: 1h19m59s, deviation: 2h18m33s, median: 0s

Traceroute

Infine, sempre con il flag aggressivo, possiamo visualizzare anche un traceroute di tutti i nodi di rete che abbiamo attraversato per raggiungere la macchina target.

Hop	Rtt	IP	Host
1	0.15	192.168.50.1	moria.home.arpa
2	0.28	192.168.51.101	metasploit-nokali

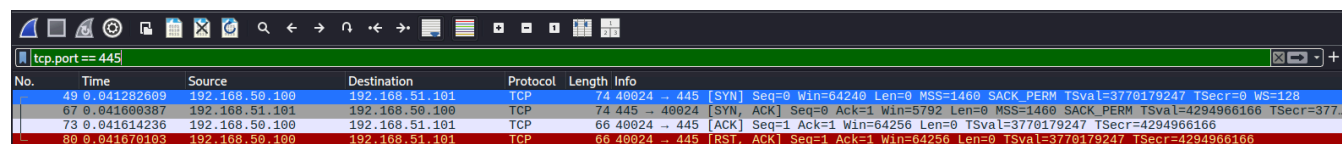
In questo caso dal nostro host (kali) abbiamo attraversato il firewall pfsense (moria.home.arpa) e poi abbiamo raggiunto la metasploitable2.

Analisi pacchetti con Wireshark (opzionale)

Possiamo vedere, analizzando con Wireshark il traffico, la differenza tra uno scan TCP e uno SYN, guardando i pacchetti inviati da nmap nelle singole scansioni.

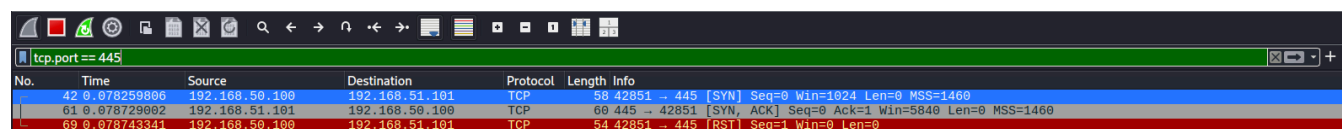
Per valutare le differenze, guardiamo la richiesta sulla porta 445 in entrambe le scansioni:

flag -sT



No.	Time	Source	Destination	Protocol	Length	Info
49	0.041282669	192.168.50.100	192.168.51.101	TCP	74	48024 → 445 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=3770179247 TSecr=0 WS=128
67	0.041690387	192.168.51.101	192.168.50.100	TCP	74	445 → 48024 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294966166 TSecr=377...
73	0.041614236	192.168.50.100	192.168.51.101	TCP	66	48024 → 445 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=3770179247 TSecr=4294966166
80	0.041670193	192.168.50.100	192.168.51.101	TCP	66	48024 → 445 [RST, ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=3770179247 TSecr=4294966166

flag -sS



No.	Time	Source	Destination	Protocol	Length	Info
42	0.078258866	192.168.50.100	192.168.51.101	TCP	58	42851 → 445 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
61	0.078729002	192.168.51.101	192.168.50.100	TCP	60	445 → 42851 [SYN, ACK] Seq=0 Ack=1 Win=5840 Len=0 MSS=1460
69	0.078743341	192.168.50.100	192.168.51.101	TCP	54	42851 → 445 [RST] Seq=1 Win=0 Len=0

Come possiamo notare, nella prima richiesta, nmap porta a termine il 3-way handshake con il server, inviando un primo pacchetto SYN, riceve il SYN,ACK e invia di conseguenza il pacchetto ACK seguito poi in chiusura dal pacchetto RST per chiudere la connessione.

Nella richiesta SYN invece, vediamo subito la mancanza del pacchetto SYN,ACK, al cui posto abbiamo subito il RST per chiudere la connessione.

Quest'ultima scansione, specialmente se fatta su tante porte, ha il vantaggio di generare meno traffico e potenzialmente essere più veloce.

Con questo si conclude la nostra introduzione al tool nmap.

Alla prossima.

